

Implementasi Sistem SOAR Open-Source

Berbasis n8n untuk Deteksi dan Respons Ancaman
Malware dan Phishing

dengan Mitigasi Aktif Human-in-the-Loop

Ravi Arnan Irianto | 2305551076

Bimbingan Tugas Akhir - September 2026

Latar Belakang

Masalah utama di SOC (Security Operations Center):

- Alert fatigue: 67% alert diabaikan karena terlalu banyak false positive
- Response manual: analisis butuh menit-jam untuk tangani 1 alert
- SOAR komersial mahal (Splunk SOAR, Palo Alto XSOAM)
- SOAR open-source (Shuffle, Cortex) masih punya keterbatasan

Yang ditawarkan tugas akhir ini:

- SOAR open-source berbasis n8n (gratis, fleksibel)
- Confidence-based: keputusan berdasarkan keyakinan, bukan tebakan
- Explainable: setiap notifikasi ada alasan kenapa dianggap berbahaya
- Self-aware: tahu kapan deteksinya sedang tidak akurat

Perbandingan dengan Pendekatan Lain

Aspek	SOC Manual	SOAR Komersial	Shuffle/Cortex	Sistem Ini (n8n)
Biaya	Gaji analis tinggi	License mahal	Gratis	Gratis
Kecepatan	Menit - jam	Detik - menit	Detik - menit	1,68 detik
Transparensi	Tergantung analis	Black-box	Black-box	Alasan di notif
Self-aware	Tergantung analis	Tidak ada	Tidak ada	Degrade otomatis
Audit trail	Manual	Ada (bayar)	Terbatas	Gratis
Phishing	Tidak ada	Tergantung playbook	Tidak ada	URLhaus auto-block
AI advisory	Tergantung analis	Tergantung vendor	Tidak ada	Ollama lokal
Multi-sumber	Manual	Tergantung integrasi	Beberapa	VT + MB
Setup	Tidak ada	Kompleks	Sedang	Docker + Ansible

* Semua fitur berjalan di 1 VPS dengan RAM ~3 GB

Arsitektur Sistem

Stack:

- Wazuh 4.9.2 (SIEM + FIM + Active Response)
- n8n 2.36.9 (workflow automation)
- Ollama llama3.2:3b (AI lokal)
- VirusTotal API (hash reputation)
- Google Safe Browsing (URL reputation)
- MalwareBazaar (malware intel)

Container (6 total):

- wazuh.manager - log analysis + active response
- wazuh.indexer - log storage (Elasticsearch)
- wazuh.dashboard - web UI
- n8n - workflow engine + webhook
- tg-callback-poller - Telegram HITL bridge
- health-monitor - uptime monitoring

Alur:

Endpoint -> Wazuh -> n8n Webhook -> VT+MB -> Ollama -> Telegram

Alur Keputusan

5 jalur keputusan berdasarkan keyakinan:

Kondisi	Tindakan	Keterangan
VT >= 20 malicious	Auto isolate	Keyakinan tinggi, langsung karantina file
VT 5-19 / MB match	HITL Telegram	Analisis pilih: Isolasi atau Abaikan
VT 1-4 / risky unknown	HITL + LLM advisory	Saran AI ditambahkan ke notifikasi
VT error / rate-limit	Degrade + advisory	Sistem jujur: tidak bisa verifikasi
VT bersih + MB bersih	Silent	Tidak ganggu analisis

Hasil Pengukuran

Uji coba dijalankan langsung di sistem live (bukan simulasi)

Metrik	Hasil	Keterangan
MTTR malware (N=30)	1,68 detik	dari alert masuk sampai file terisolasi
MTTR phishing (N=10)	2,13 detik	dari URL terdeteksi sampai domain diblokir
Throughput (N=20)	34 alert/detik	load test 5 thread paralel
FN rate (N=15)	0%	semua file risky berhasil terdeteksi
FP suppression (N=8)	100%	8 alert baseline -> 0 notifikasi

Catatan:

- MTTR 1,68 detik itu waktu end-to-end (VT cache hangat). Kalau VT cold, tambah ~3-5 detik.
- Phishing lebih lama sedikit karena ada pengecekan URLScan, tapi GSB langsung.
- Load test 34 alert/detik itu kapasitas webhook n8n. Pipeline backend jalan async.
- FN rate 0% artinya tidak ada file berisiko yang lolos dari deteksi.

Roadmap Pengerjaan

Kategori	Item	Status	Tanggal
A - Bug fix	block-domain persist	Selesai	2026-07-02
A - Bug fix	Notifikasi ganda diperbaiki	Selesai	2026-07-02
B - Threat intel	Hybrid: risky ext -> HITL	Selesai	2026-07-02
B - Threat intel	MalwareBazaar ensemble	Selesai	2026-09-02
B - Threat intel	TTL diferensial cache	Selesai	2026-09-02
C - Evaluasi	MTTR & FP suppression	Selesai	2026-07-02
C - Evaluasi	Benchmark N>=30	Selesai	2026-09-02
C - Evaluasi	MITRE ATT&CK mapping	Selesai	2026-09-02
D - Hardening	Caddy + TLS + Ansible	Selesai	2026-07-06
F - Explainable	Self-aware + audit trail	Selesai	2026-07-06
F - Explainable	LLM-fallback advisory	Selesai	2026-09-02
G - Perluasan	Phishing proaktif	Selesai	2026-09-02
G - Perluasan	Magic-byte detection	Selesai	2026-09-02
H - Maintenance	n8n update + pin versi	Selesai	2026-09-02
F - Lanjutan	Trusted autonomy	Belum	-
F - Lanjutan	RAG anti-halusinasi	Belum	-
E - Arsitektur	HA: queue-mode + Redis	Belum	-
H - Maintenance	Upgrade Wazuh 4.14.7	Belum	PascTA

Rencana ke Depan

Trusted Autonomy

Sekarang: semua keputusan butuh konfirmasi analis (HITL).

Rencana: kalau keyakinan sangat tinggi, boleh auto tanpa tunggu analis, tapi ada timeout & SLA.

RAG (Retrieval-Augmented Generation)

Masalah: LLM kadang mengarang rekomendasi (halusinasi).

Rencana: kasih LLM akses ke playbook & threat-intel supaya jawabannya berbasis data.

Arsitektur HA

Sekarang: 1 container n8n + SQLite (single point of failure).

Rencana: n8n queue-mode + Redis + PostgreSQL + Prometheus/Grafana.

Upgrade Wazuh

4.9.2 -> 4.14.7. Deferred pasca-TA karena agent juga harus di-upgrade bareng.

Terima Kasih

*Sistem ini dibangun dengan prinsip:
bukan menggantikan analis, tapi membantu analis
ambil keputusan lebih cepat dengan informasi yang cukup.*

Ravi Arnan Irianto | 2305551076

raviarnankeren@gmail.com